

Kaynak

Hazırlayan

Giriş ve Oda Hakkında

Hikaye;

1899 yılında, “[Garcia'ya Bir Mesaj](#)” güvenilirlik, inisiyatif ve işi bitirme konusunda güçlü bir metafor haline geldi: mazeret yok, gereksiz sorular yok, sadece icra var.

“Patron” evdeyken olduğu kadar, yokken de işini yapan adama hayranlık duyuyorum. Ve Garcia'ya bir mektup verildiğinde, aptalca sorular sormadan, onu en yakın kanalizasyona atmak ya da teslim etmekten başka bir şey yapmak gibi gizli niyetler gütmekten sessizce mektubu alan adam, asla “işten çıkarılmaz” ve daha yüksek ücret için greve gitmek zorunda kalmaz. Medeniyet, tam da bu tür bireyleri bulmak için uzun ve endişeli bir arayıştır. Böyle bir adamın istediği her şey yerine getirilir; onun gibi insanlar o kadar nadirdir ki, hiçbir işveren onu işten çıkarmaya cesaret edemez. Her şehirde, kasabada ve köyde, her ofiste, dükkanda, mağazada ve fabrikada aranır. Dünya böyle insanlara ihtiyaç duyar; Garcia'ya mesaj götürebilecek bir adama çok ihtiyaç vardır. (Elbert Hubbard, 1899)

Keşif

Mesajı Anlamak

İlk olarak Garcia adlı kişiye gönderilen mesajın içeriğini anlamamız gerekiyor. Bizim için kilit rol oynayacak bilgiler keşfedebiliriz.

Garcia'ya Bir Mesaj

Elbert Hubbard (1899)

Tüm bu Küba meselesinde, hafızamın ufkunda günberideki Mars gibi parlayan bir adam var.

İspanya ile Amerika Birleşik Devletleri arasında savaş çıktığında, İsyancıların lideriyle hızla iletişim kurmak çok önemliydi. Garcia, Küba'nın dağlık kalelerinde bir yerlerdeydi ama kimse tam olarak nerede olduğunu bilmiyordu. Ona ne posta ne de telgraf ulaşabiliyordu. Başkan'ın onun iş birliğine, hem de acilen ihtiyacı vardı.

Ne yapmalıydı?

Biri Başkan'a şöyle dedi: “**Rowan adında bir adam var; Garcia'yı bulabilirse o bulur.**”

Rowan çağrıldı ve kendisine Garcia'ya iletmek üzere bir mektup verildi. "Rowan denilen o adamın" mektubu nasıl aldığını, yağlı deri bir keseye koyup kalbinin üzerine nasıl bağladığını, dört gün sonra açık bir tekneyle gece vakti Küba kıyılarına nasıl çıktığını, ormanda nasıl kaybolduğunu ve üç hafta sonra adanın öteki ucundan nasıl çıktığını, düşman bir ülkeyi yaya olarak geçip mektubu Garcia'ya nasıl teslim ettiğini burada ayrıntılarıyla anlatmaya pek niyetim yok.

Vurgulamak istediğim nokta şu: McKinley, Rowan'a Garcia'ya iletilmesi için bir mektup verdi; Rowan mektubu aldı ve **"O nerede?" diye sormadı.**

Tanrı aşkına! Öyle bir adamın heykeli ölümsüz bronzdan dökülmeli ve bu heykel ülkedeki her üniversiteye dikilmelidir. Gençlerin ihtiyacı olan şey kitap bilgisi ya da şununla bununla ilgili talimatlar değildir; ihtiyaçları olan şey, bir güvene sadık kalmalarını, derhal harekete geçmelerini, enerjilerini odaklamalarını ve o işi yapmalarını sağlayacak bir karakter sağlamlığıdır: **"Garcia'ya mesajı götürmek!"**

General Garcia artık hayatta değil ama başka "Garcia'lar" var. Birçok kişinin emeğine ihtiyaç duyulan bir girişimi yürütmeye çalışan hiçbir insan yoktur ki, ortalama bir insanın yetersizliği, bir şeye odaklanma konusundaki acizliği veya isteksizliği karşısında zaman zaman dehşete düşmemiş olsun.

Gevşek yardımlar, aptalca dikkatsizlikler, paspal bir ilgisizlik ve yarım ağızla yapılan işler kural haline gelmiş gibi görünüyor; hiç kimse başkalarını yardım etmeye zorlamadıkça ya da rüşvet vermedikçe başarılı olamıyor; ya da belki de Tanrı iyiliğiyle bir mucize gerçekleştirip ona yardımcı olarak bir ışık meleği gönderiyor.

Siz, okuyucu, bunu bir teste tabi tutun: Ofisinizde oturuyorsunuz, altı katip emrinizde. Herhangi birini çağırın ve şu ricada bulunun: "Lütfen ansiklopediye bak ve bana Corregio'nun hayatı hakkında kısa bir not hazırla."

Katip sessizce "Peki efendim," deyip işini yapmaya mı gidecek?

Hayatınız üzerine yemin ederim ki hayır. Size donuk gözlerle bakacak ve şu sorulardan birini veya birkaçını soracaktır:

- O kimdi?
- Hangi ansiklopedi?
- Ansiklopedi nerede?
- Ben bunun için mi işe alındım?
- Bismarck'ı mı demek istediniz?
- Charlie yapsa olmaz mı?
- Öldü mü?
- Acele mi?
- Kitabı getireyim de kendiniz baksanız olmaz mı?
- Bunu ne için bilmek istiyorsunuz?

Size on birine bir bahse girerim ki, soruları cevapladıktan, bilginin nasıl bulunacağını ve neden istediğinizi açıkladıktan sonra, katip gidip diğer katiplerden birini "Garcia'yı" bulmak için yardımına çağırarak ve sonra geri gelip size böyle bir adamın olmadığını söyleyecektir. Tabii ki bahsi kaybedebilirim, ama ortalama yasına göre kaybetmem.

Eğer akıllıysanız, "yardımcınıza" Corregio'nun K harfinde değil C harfinde olduğunu açıklamakla uğraşmazsınız; tatlı bir şekilde gülümser, "Boşver," der ve gidip kendiniz bakarsınız. İşte bu bağımsız eylem yetersizliği, bu ahlaki uyuşukluk, bu irade zayıflığı, bir işin ucundan neşeyle tutup kaldırma isteksizliği; saf sosyalizmi geleceğin çok uzaklarına iten şeylerdir. Eğer insanlar kendileri için bile harekete geçmeyeceklerse, çabalarının meyvesi herkes için olduğunda ne yapacaklar?

Birçok işçiyi yerinde tutan tek şey, cumartesi gecesi "kovulma" korkusudur. Bir stenograf için ilan verin; başvuran on kişiden dokuzu ne yazım kurallarını bilir ne de noktalama işaretlerini ve bunu gerekli de görmezler.

Böyle biri Garcia'ya mektup yazabilir mi?

Büyük bir fabrikadaki ustabaşı bana, "Şu muhasebeciyi görüyor musun?" dedi. "Evet, nesi var?" "Harika bir hesap uzmanıdır ama onu şehre bir iş için göndersem, işi halledebilir de; öte yandan, yolda dört meyhaneye uğrayıp Ana Cadde'ye vardığında ne için gönderildiğini unutabilir de."

Böyle birine Garcia'ya bir mesaj götürmesi için güvenilebilir mi?

Son zamanlarda "atölyelerde ezilenler" ve "dürüst bir iş arayan evsiz avareler" için ifade edilen birçok yapmacık sempati duyuyoruz; bunlarla birlikte güç sahibi adamlar için de pek çok sert söz söyleniyor.

Sırtını döndüğünde kaytarmaktan başka bir şey yapmayan "yardımcılarla" sabırla uğraşan, akıllıca işler yapmaları için beyhude yere çabalarken vaktinden önce yaşlanan işveren hakkında ise hiçbir şey söylenmiyor. Her mağazada ve fabrikada sürekli bir ayıklama süreci işlemektedir. İşveren, işletmenin çıkarlarını ileriye götürme konusundaki yetersizliğini gösteren "yardımcıları" sürekli uzaklaştırıyor ve başkalarını alıyor. İşler ne kadar iyi olursa olsun bu seçme işlemi devam eder; sadece işler zorsa ve iş azsa bu seçme daha titiz yapılır; ama yetersiz ve layık olmayanlar dışarıya, sonsuza dek dışarıya giderler. Bu, en güçlü olanın hayatta kalmasıdır. Kendi çıkarı, her işvereni en iyileri tutmaya iter: **Garcia'ya mesajı ulaştıranları.**

Kendi işini yönetecek yeteneği olmayan, ancak başkası için de tamamen değersiz olan, çünkü sürekli olarak işverenin kendisine zulmettiği ya da zulmetmeyi planladığı yönündeki çılgınca şüpheyi taşıyan, gerçekten parlak yeteneklere sahip bir adam tanıyorum. Emir veremiyor ve emir almayı da reddediyor. Garcia'ya götürmesi için ona bir mesaj verilse, cevabı muhtemelen "Kendin götür," olurdu.

Bu gece bu adam sokaklarda iş arayarak dolaşıyor, rüzgar eskimiş ceketinin içinden ılık çalarak geçiyor. Onu tanıyan hiç kimse işe almaya cesaret edemez, çünkü o tam bir

memnuniyetsizlik kışkırtıcısıdır. Mantiğa kapalıdır ve onu etkileyebilecek tek şey kalın tabanlı bir botun darbesidir.

Elbette biliyorum ki, ahlaki açıdan bu kadar kusurlu biri, bedensel bir engelli kadar acınmaya değerdir; ama acırken, büyük bir girişimi yürütmeye çalışan, çalışma saatleri düdükle sınırlı olmayan ve paspal ilgisizlik, gevşek yetersizlik ve kalpsiz nankörlükle mücadele ederken saçları hızla ağaran o adamlar için de bir gözyaşı dökelim; zira onların girişimi olmasaydı, o nankörler hem aç hem de evsiz kalırdı.

Meseleyi çok mu sert dile getirdim? Muhtemelen; ama tüm dünya perişanların halinden bahsederken, ben başarılı olan adam için bir sempati sözü söylemek istiyorum; büyük zorluklara rağmen başkalarının çabalarını yöneten ve başarılı olduktan sonra elinde çıplak konaklama ve giysiden başka bir şey kalmadığını gören adam için. Ben yemek sepeti taşıdım ve günlük yevmiyeyle çalıştım, aynı zamanda işveren de oldum; biliyorum ki her iki taraf için de söylenecek bir şeyler var. Yoksulluğun kendisinde bir üstünlük yoktur; paçavralar bir tavsiye mektubu değildir; ve tüm yoksul adamların erdemli olmadığı gibi, tüm işverenler de açgözlü ve zorba değildir.

Kalbim, "patron" oradayken olduğu gibi, o yokken de işini yapan adamla birliktedir. Ve kendisine Garcia için bir mektup verildiğinde, aptalca sorular sormadan, onu en yakın lağıma atma niyeti gütmekten ve teslim etmekten başka bir şey düşünmeden mektubu sessizce alan adam; ne işten çıkarılır ne de daha yüksek ücret için greve gitmek zorunda kalır. Medeniyet, işte tam da bu tür bireyler için uzun ve endişeli bir arayıştır. Böyle bir adam ne isterse yerine getirilir; onun gibiler o kadar nadirdir ki, hiçbir işveren onun gitmesine izin vermeyi göze alamaz. O her şehirde, kasabada ve köyde; her ofis, dükkan ve fabrikada aranır. Dünya böyleleri için feryat ediyor; ona çok ama çok ihtiyaç var: **Garcia'ya mesajı ulaştırabilen adama.**

Nmap Taraması

İlk sorunun cevabını bulduğumuza göre bir sonraki araştırmamıza geçiyoruz. Bize verilen IP adresinden yola çıkarak iletmemiz gereken mesajı bulmamız gerekiyor ve sonra da güvenli dosya aktarım sunucusu olan SFTP ile mesajı iletmemiz isteniyor.

```
root@ip-10-81-120-245:~# nmap -sV -p- 10.81.184.36
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-08 14:10 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or specify
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Try
Stats: 0:00:39 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 66.67% done; ETC: 14:11 (0:00:18 remaining)
Stats: 0:00:44 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 66.67% done; ETC: 14:11 (0:00:21 remaining)
Nmap scan report for 10.81.184.36
Host is up (0.00017s latency).
Not shown: 65532 closed ports
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.11 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http      nginx 1.24.0 (Ubuntu)
5000/tcp  open  upnp?
```

Port Analizi ve Strateji

1. Port 22 (SSH) - OpenSSH 9.6p1

- **Durum:** Oldukça güncel bir sürüm.
- **Analiz:** Genellikle bu aşamada SSH üzerinden bir açık bulmak zordur. Burası muhtemelen odanın ilerleyen safhalarında bir kullanıcı adı ve parola (veya özel anahtar) bulunduğunda sisteme giriş yapacağın kapı olacak.

2. Port 80 (HTTP) - Nginx 1.24.0

- **Durum:** Standart web sunucusu.
- **Analiz:** İlk kurcalaman gereken yer burası. Bir tarayıcı açıp IP adresine gitmelisin.
- **İpucu:** Garcia temalı bu odada, web sitesinin kaynak kodlarını (Ctrl+U) kontrol etmeyi veya `robots.txt` gibi dosyaları taramayı unutma. Nginx sürümü de oldukça güncel, yani bir "exploit" aramaktan ziyade içerik keşfine odaklanmalısın.

3. Port 5000 (UPnP?)

Buradaki soru işareti (?), Nmap'in o portta bir servis bulunduğunu ancak bunun **gerçekten UPnP olup olmadığından emin olamadığını** gösterir. CTF'lerde 5000 portu genellikle şunlar için kullanılır:

- **Flask/Python Web Uygulamaları:** Geliştiricilerin sıkça kullandığı bir porttur.
- **Docker Registry:** Konteyner servisleri bazen burada çalışır.
- **REST API:** Bir uygulamanın arka yüzü (backend) burada olabilir.

5000 Portu dikkatimi çektiği için o portun üzerinde keşfimi yoğunlaştırıyorum.

Detaylı nmap taraması;

```

root@ip-10-81-120-245:~# nmap -sV -sC -p 5000 10.81.184.36
Starting Nmap 7.80 ( https://nmap.org ) at 2026-02-08 14:20 GMT
mass_dns: warning: Unable to open /etc/resolv.conf. Try using --system-dns or speci
mass_dns: warning: Unable to determine any DNS servers. Reverse DNS is disabled. Tr
Stats: 0:00:41 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Stats: 0:00:46 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
Service scan Timing: About 0.00% done
Nmap scan report for 10.81.184.36
Host is up (0.00042s latency).

PORT      STATE SERVICE VERSION
5000/tcp  open  upnp?

| fingerprint-strings:
|   GetRequest:
|     HTTP/1.1 200 OK
|     Server: Werkzeug/3.1.3 Python/3.12.3
|     Date: Sun, 08 Feb 2026 14:20:34 GMT
|     Content-Type: text/html; charset=utf-8
|     Content-Length: 8126
|     Connection: close
|     <!DOCTYPE html>
|     <html lang="en">
|     <head>
|     <meta charset="UTF-8" />
|     <meta name="viewport" content="width=device-width, initial-scale=1.0" />
|     <title>SFTP | Home</title>
|     <link
|     rel="stylesheet"
|     href="/static/css/bootstrap-icons.css"
|     <link
|     rel="stylesheet"
|     href="/static/css/bootstrap-icons.css"

```

curl taraması;

```

root@ip-10-81-120-245:~# curl -I http://10.81.184.36:5000
HTTP/1.1 200 OK
Server: Werkzeug/3.1.3 Python/3.12.3
Date: Sun, 08 Feb 2026 14:26:57 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 8126
Connection: close

```

gobuster taraması;

```
root@ip-10-81-120-245:~# gobuster dir -u http://10.81.184.36 -w /usr/share/wordlists/dirb/common.txt
=====
Gobuster v3.6
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)
=====
[+] Url: http://10.81.184.36
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.6
[+] Timeout: 10s
=====
Starting gobuster in directory enumeration mode
=====
/backup (Status: 200) [Size: 2562]
/fetch (Status: 200) [Size: 2264]
/start (Status: 302) [Size: 189]
/stop (Status: 302) [Size: 189]
/status (Status: 200) [Size: 992]
/success (Status: 302) [Size: 189]
/upload (Status: 405) [Size: 153]
Progress: 4614 / 4615 (99.98%)
=====
Finished
=====
root@ip-10-81-120-245:~#
```

Bulguların Teknik Analizi

1. Port 5000: Beklenmedik Bir Web Sunucusu

Nmap başta **upnp?** dese de, servis taraması gerçek kimliğini ortaya çıkardı:

- **Server:** Werkzeug/3.1.3 Python/3.12.3
- **Anlamı:** Bu bir **Python Flask** uygulamasıdır. **Werkzeug**, Flask'ın kullandığı alt kütüphanedir.
- **Başlık (Title):** <title>SFTP | Home</title> - Bu çok önemli! Uygulama kendisini bir **SFTP** (Secure File Transfer Protocol) arayüzü olarak tanımlıyor.
- **Tasarım:** Sayfanın **Tailwind CSS** ve **Bootstrap** kullanılarak modern bir şekilde tasarlandığını görüyoruz.

2. Gobuster Sonuçları: Gizli Yollar

Port 80 (Nginx) üzerinde yaptığın tarama çok kritik dizinler döndürdü:

- **/backup** : Muhtemelen eski yapılandırma dosyaları veya kaynak kodları içeriyor. **İlk buraya bakmalısın.**
- **/fetch** : Bir dosya getirme mekanizması olabilir. (SSRF zafiyeti barındırma potansiyeli yüksektir).
- **/upload** : Durum **405 (Method Not Allowed)** dönmüş. Yani tarayıcıyla (GET) giremezsin ama bir dosya yüklemek için (POST) kullanılabilir.
- **/status** : Sistemin veya çalışan işlemlerin durumunu gösteriyor olabilir.

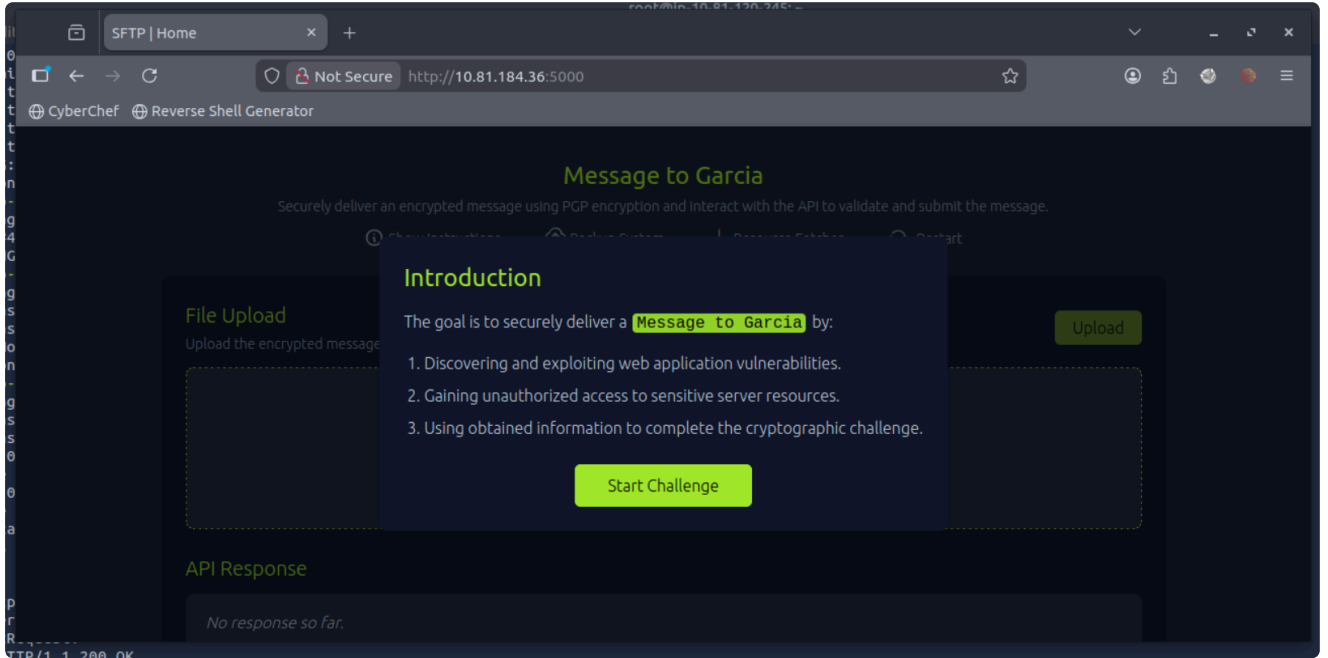
Write-up'ının "Initial Enumeration" kısmına şunları ekleyebilirsin:

"Nmap taraması sonucunda 5000. portta alışlagelmişin dışında bir servis tespit ettim. İlk bakışta UPnP gibi görünse de, detaylı tarama bunun bir **Python Werkzeug (Flask)** sunucusu olduğunu ve bir **SFTP web arayüzü** barındırdığını gösterdi.

Ardından ana dizin üzerinde yaptığım Gobuster taraması, saldırı yüzeyini genişletti. **/backup** dizini potansiyel bilgi sızıntısı için en güçlü adayken, **/fetch** ve **/upload** dizinleri uygulamanın dosya işleme yeteneklerini işaret ediyor."

🚀 Bir Sonraki Hamlen Ne Olmalı?

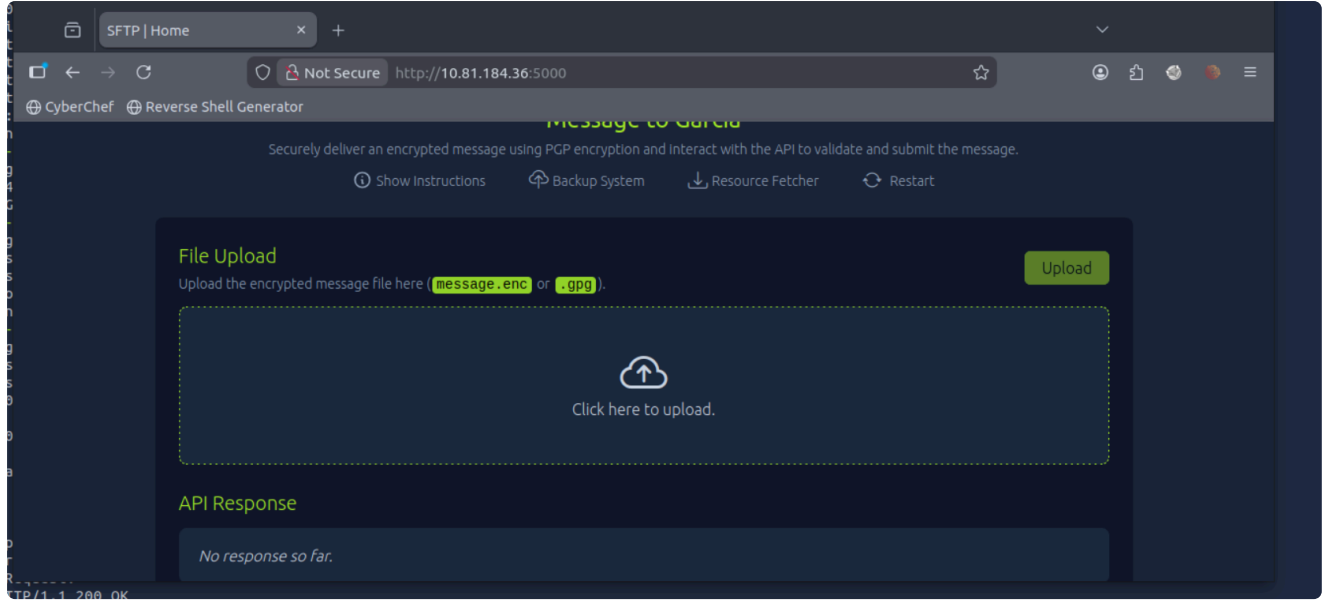
1. **/backup** dizinine git: İçeride bir **.zip** , **.bak** veya **id_rsa** (SSH anahtarı) var mı kontrol et.
2. **/fetch** dizinini incele: Bu sayfa senden bir URL veya dosya ismi istiyor mu? Eğer istiyorsa, yerel dosyaları okumayı deneyebilirsin (LFI - Local File Inclusion). Örneğin: **http://10.81.184.36/fetch?file=/etc/passwd**
3. **5000 Portuna Göz At:** Tarayıcından **http://10.81.184.36:5000** adresine git ve oradaki "SFTP" arayüzünde giriş yapmanı gerektiren veya dosya listelemeni sağlayan bir yer var mı bak.



Amaç, aşağıdakileri yaparak Garcia'ya bir mesajı güvenli bir şekilde iletmektir:

1. Web uygulamalarının güvenlik açıklarını keşfetmek ve bunlardan yararlanmak.
2. Hassas sunucu kaynaklarına yetkisiz erişim sağlamak.
3. Elde edilen bilgileri kullanarak şifreleme görevini tamamlamak.

Evet buradan anlıyoruz ki dosyaları buradan yollayacağız! Ancak elimizde şuanda dosyalar yok.



Şimdi sırayla gobuster ile bulduğumuz enumeration uzantılarını deneyelim.

